

Clase 181 — El SOC moderno: roles, niveles y procesos

Parte: 8 — Blue Team, detección y SOC · Fuente: Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases — Don Murdoch · Duración estimada: 90 min · Nivel: Fundamentos

Objetivo

Entender qué es un Security Operations Center (SOC) moderno: cómo se organiza en niveles (L1/L2/L3), qué roles lo componen, cómo fluye una alerta desde que se genera hasta que se cierra, y qué modelos operativos existen (interno, MSSP, híbrido). Al final tendrás un mapa mental del ecosistema defensivo sobre el que se apoya toda la Parte 8.

Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Enumerar** los roles clave de un SOC y sus responsabilidades.
- 2. **Describir** el ciclo de vida de una alerta (triaje → investigación → escalado → respuesta → cierre).
- 3. **Diferenciar** los modelos SOC interno, MSSP, virtual e híbrido según necesidad.
- 4. **Aplicar** conceptos de MTTD y MTTR para razonar sobre el rendimiento del SOC.
- 5. **Situar** cada herramienta (SIEM, EDR, SOAR, TIP) dentro del flujo operativo.

Temas

#	Tema	Por qué importa
1	Definición y misión del SOC	Alinea detección y respuesta con el riesgo del negocio
2	Niveles L1/L2/L3 y funciones	Define quién hace qué y cómo se escala
3	Roles: analista, hunter, ingeniero de detección, IR	Evita vacíos de responsabilidad
4	Ciclo de vida de una alerta	Estandariza el trabajo y reduce errores
5	Modelos operativos (interno/MSSP/híbrido)	Impacta coste, control y cobertura
6	Runbooks y playbooks	Consistencia y velocidad ante incidentes
7	Métricas base (MTTD, MTTR, dwell time)	Permiten mejorar con datos, no con opinión
8	Turnos y modelo de cobertura (8x5 vs 24x7)	Determina la ventana de exposición

Definiciones y características

- **SOC (Security Operations Center):** equipo y plataforma que monitorea, detecta, investiga y responde a amenazas de forma continua. Característica clave: opera con procesos definidos, no ad hoc.
- **Analista L1 (triage):** primer filtro; clasifica alertas, descarta falsos positivos evidentes y escala lo que merece investigación. Característica: alto volumen, decisiones rápidas.
- **Analista L2 (investigación):** profundiza, correlaciona múltiples fuentes y determina alcance. Característica: pivota entre telemetría de red, endpoint e identidad.
- **L3 / Threat Hunter / Ingeniero de detección:** caza proactiva, crea y afina detecciones, lidera incidentes complejos. Característica: trabaja por hipótesis, no solo por alertas.
- **MTTD (Mean Time To Detect):** tiempo medio desde el compromiso hasta la detección. Cuanto menor, menos daño.
- **MTTR (Mean Time To Respond):** tiempo medio hasta contener/erradicar. Mide la eficacia de la respuesta.
- **Dwell time:** tiempo que el atacante permanece sin ser detectado. Métrica reina del blue team.

Herramientas y preparación

No necesitas software ofensivo en esta clase; es conceptual y de diseño. Prepara:

- Un editor de diagramas (draw.io / Excalidraw) para modelar el flujo de alertas.
- Una hoja de cálculo para tu **matriz RACI** de roles.
- Acceso al catálogo de MITRE ATT&CK (attack.mitre.org) para familiarizarte con el vocabulario.
- Opcional: revisa la documentación de un SIEM (Splunk, Elastic) para ubicar dónde encaja en el SOC.

Recuerda que todo laboratorio práctico posterior se hace en un **entorno propio y aislado**.

Laboratorio guiado — Diseña tu SOC en papel

Ejercicio aplicado de arquitectura organizativa (no ofensivo):

1. **Define el alcance.** Imagina una empresa de 500 empleados, un data center pequeño y nube (Microsoft 365 + AWS). Anota qué activos son críticos.
2. **Elige el modelo operativo.** Justifica interno vs MSSP vs híbrido según presupuesto y madurez. Documenta 3 pros y 3 contras.
3. **Dibuja el flujo de una alerta.** Desde que Sysmon/EDR genera un evento hasta que se cierra el ticket. Marca los puntos de escalado L1→L2→L3.
4. **Construye la matriz RACI.** Para 5 actividades (triage, hunting, creación de reglas, respuesta a incidentes, reporte a dirección) asigna Responsible/Accountable/Consulted/Informed.
5. **Define la cobertura.** Decide 8x5 vs 24x7 y calcula la ventana de exposición nocturna/fin de semana. Propón una mitigación (on-call, MSSP nocturno).
6. **Selecciona la pila de herramientas.** Ubica SIEM, EDR, SOAR, TIP y ticketing en el flujo del paso 3.
7. **Fija 4 métricas.** Elige MTTD, MTTR, % falsos positivos y cobertura ATT&CK; define cómo medirías cada una.

Ejercicios

1. Escribe la descripción de puesto (3 responsabilidades) de un analista L1 y de un ingeniero de detección.
2. Redacta el runbook de 6 pasos para una alerta de "inicio de sesión imposible" (geografía incompatible).
3. Compara MTTD y dwell time con un ejemplo numérico propio.
4. Diseña el criterio de escalado L1→L2 con 3 condiciones objetivas.
5. Argumenta cuándo un MSSP es mala idea para una organización concreta.
6. Propón una métrica que un mal SOC podría manipular y explica cómo evitar el gaming.

Reto verificable

Entrega un documento de 1–2 páginas con: (a) organigrama del SOC con roles, (b) diagrama del ciclo de vida de la alerta, (c) matriz RACI, (d) 4 métricas con su fórmula. **Criterio de aceptación:** el flujo de alerta muestra al menos un punto de escalado y un punto de cierre con documentación, y cada rol del organigrama aparece como "Responsable" de al menos una actividad en la RACI.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Todos los analistas hacen de todo	Falta separación L1/L2/L3; define niveles y criterios de escalado
Métrica MTTR baja pero incidentes reincidentes	Se cierra rápido sin erradicar causa raíz; añade métrica de reincidencia
Cola de alertas siempre saturada	Exceso de falsos positivos; prioriza afinar reglas antes que contratar gente
Nadie es dueño de las detecciones	No hay ingeniero de detección; asigna el rol formalmente
SOC 24x7 pero apagado los fines	Cobertura mal diseñada; documenta on-call o MSSP suplementario

Preguntas frecuentes

? ¿Necesito un SOC 24x7 desde el día uno? No. Empieza con 8x5 y on-call, mide tu ventana de exposición y crece según el riesgo real. Un 24x7 mal dotado es peor que un 8x5 bien afinado.

? ¿SIEM y SOC son lo mismo? No. El SIEM es una herramienta; el SOC es el equipo y los procesos que la usan (junto con EDR, SOAR, hunting, etc.).

? ¿Cuál es la diferencia entre threat hunting y monitoreo de alertas? El monitoreo reacciona a lo que una regla ya disparó; el hunting busca proactivamente lo que ninguna regla detectó, partiendo de hipótesis.

Referencias

- Murdoch, D. *Blue Team Handbook: SOC, SIEM, and Threat Hunting Use Cases*.

- Bejtlich, R. *The Practice of Network Security Monitoring*. No Starch Press.
- MITRE ATT&CK — <https://attack.mitre.org/>
- SANS, "Building a World-Class Security Operations Center" (whitepaper).
- NIST SP 800-61r2, *Computer Security Incident Handling Guide* — <https://csrc.nist.gov/pubs/sp/800/61/r2/final>

Siguiente clase

Clase 182 - Logging y fuentes de telemetría